

MODULE 03 · DOMAIN 1 - DESIGN SECURE ARCHITECTURES

Encryption, Secrets and Governance

Protecting data at rest and in transit, and proving that you did.

DOMAIN 1 of 4 EXAM WEIGHT 30% MODULE 3 of 22

AWS encrypts the data. You control **who can use the key**. That distinction is the whole of KMS.

The three kinds of KMS key

KEY TYPE	WHO CONTROLS IT	CHOOSE IT WHEN
AWS owned	AWS entirely. Invisible to you	Default. No key requirements
AWS managed	AWS creates, you see CloudTrail use	Service default encryption
Customer managed	You. Policy, rotation, sharing	Audit, cross-account, own rotation
Imported material	You supply the key material	Regulation says you originate it
CloudHSM	You, in dedicated hardware	Single-tenant hardware required

ON THE EXAM

Any need to control, audit, rotate or share the key means a customer managed key.

KMS facts that decide questions

- ◆ **KMS keys are regional.** To encrypt in another Region you need a key there, or a multi-Region key.
- ◆ **Automatic rotation** for customer managed keys is annual, and old material is retained so old data still decrypts.
- ◆ **Deletion is not immediate.** There is a mandatory waiting period of seven to thirty days.
- ◆ **Envelope encryption.** KMS encrypts a data key; the data key encrypts your data. This is why large objects are practical.
- ◆ **Cross-Region replication of encrypted S3 objects** requires a key in the destination Region.

ON THE EXAM

'Encrypt an existing unencrypted RDS database' is never done in place. You snapshot, copy the snapshot with encryption, and restore.

Secrets Manager or Parameter Store?

SECRETS MANAGER

When rotation matters

- Built-in automatic rotation, including for RDS
- Charged per secret per month
- Cross-account and cross-Region replication
- Generates random passwords for you

SSM PARAMETER STORE

When it is configuration

- Standard parameters are free
- SecureString values encrypted with KMS
- No native rotation without writing Lambda
- Good for endpoints, flags, version strings

THE TIEBREAKER

The word 'rotation' points at Secrets Manager. The word 'cost' with simple config points at Parameter Store.

The governance services, separated

SERVICE	THE ONE-LINE DIFFERENCE
CloudTrail	Who did what. An API call audit log.
CloudWatch	How things are performing. Metrics, logs, alarms.
AWS Config	Is this resource configured correctly, and how did it change over time.
GuardDuty	Threat detection from logs. Finds malicious behaviour.
Inspector	Vulnerability scanning of workloads. Finds unpatched software.
Macie	Finds sensitive data, such as personal information, in S3.
Security Hub	Aggregates findings from the others into one view.
Detective	Investigates a finding to establish root cause.

ON THE EXAM

CloudTrail records actions. Config records state. That single sentence separates the two most-confused services here.

Encryption in transit and at rest

- ◆ **ACM** issues and auto-renews public TLS certificates at no charge, for use on CloudFront, ALB and API Gateway.
- ◆ **ACM public certificates cannot be exported.** If a question needs the certificate on an EC2 instance directly, it is not ACM public.
- ◆ **S3 encrypts all new objects by default** with SSE-S3. SSE-KMS adds key control and an audit trail.
- ◆ **Enforce HTTPS** with a bucket policy denying requests where aws:SecureTransport is false.
- ◆ **EBS, RDS, EFS and DynamoDB** all support encryption at rest with a checkbox and a KMS key.

ON THE EXAM

'Certificate renewal is being forgotten' is an ACM question. Managed renewal is the feature being tested.

A web application on EC2 connects to an Amazon RDS for MySQL database. The database password is stored in an environment variable set at instance launch.

A new policy requires that database credentials rotate every thirty days with no application downtime and no manual steps. The team does not want to write or maintain rotation code.

Which solution meets these requirements?

- ☐ A Store the password in Secrets Manager and enable managed rotation for RDS
- ☐ B Store the password as a SecureString in Parameter Store and rotate it with a scheduled Lambda function
- ☐ C Store the password in an encrypted S3 object and have the application read it at start-up
- ☐ D Store the password in a KMS encrypted environment variable and redeploy monthly

◆ PAUSE AND DECIDE

Which solution meets these requirements?

- A

 Secrets Manager with managed rotation
Rotation for RDS is a built-in feature. It updates the database and the stored secret together, with no code to maintain.
- B

 Parameter Store plus Lambda
Achieves rotation but requires writing and owning the function, which the question explicitly excludes.
- C

 Encrypted S3 object
Stores the secret but provides no rotation at all. Reading at start-up also means a restart to pick up changes.
- D

 Encrypted environment variable
Monthly redeployment is a manual step and causes exactly the downtime the requirement forbids.

THE SIGNAL

'Rotate credentials automatically' plus 'no code to maintain' is Secrets Manager managed rotation.

A financial services company must produce, on demand, a record of every change made to security group rules across sixty AWS accounts for the previous two years, including who made each change and what the rule looked like before and after.

Auditors also want automatic notification whenever a security group permits unrestricted inbound access.

Which combination of services meets both requirements?

- A CloudWatch Logs for the history, and a metric filter for notification
- B AWS Config with an organisation aggregator, and a Config rule with SNS notification
- C GuardDuty for the history, and Security Hub for notification
- D VPC Flow Logs for the history, and Amazon Inspector for notification

◆ PAUSE AND DECIDE

Which combination of services meets both requirements?

- A

 CloudWatch Logs and metric filter
CloudWatch handles performance and log data. It does not maintain configuration history or before-and-after resource state.
- B

 Config with aggregator and rule
Config records configuration state over time, aggregates across accounts, and its rules evaluate compliance and notify.
- C

 GuardDuty and Security Hub
Threat detection and finding aggregation. Neither keeps a configuration timeline of security group rules.
- D

 Flow Logs and Inspector
Flow Logs record traffic, not rule changes. Inspector scans for software vulnerabilities, not configuration compliance.

THE SIGNAL

'What did this resource look like before and after' is the definition of AWS Config. CloudTrail would tell you who called the API, but not the resulting state over time.

A company stores millions of customer documents in S3. Legal has asked whether any of them contain national insurance numbers, passport numbers or payment card details, since the buckets were populated by several teams over six years.

They need an ongoing report rather than a one-off answer, and nobody knows the file formats in advance.

Which service should be used?

- | | |
|---|--|
| ☐ A Amazon Macie | ☐ B Amazon Inspector |
| ☐ C Amazon GuardDuty | ☐ D AWS Config with a custom rule |

◆ PAUSE AND DECIDE

Which service should be used?

- A** Amazon Macie
Purpose-built to discover and classify sensitive data in S3, with managed identifiers for exactly these data types and continuous scanning.
- B** Amazon Inspector
Scans compute workloads and container images for software vulnerabilities. It does not read object contents for sensitive data.
- C** Amazon GuardDuty
Detects malicious activity from log analysis. It flags suspicious access to a bucket, not what the objects contain.
- D** Config with a custom rule
Evaluates resource configuration, such as whether a bucket is encrypted. It does not inspect object contents.

THE SIGNAL

Sensitive data inside S3 objects means Macie. Vulnerabilities in workloads means Inspector. Malicious behaviour means GuardDuty.

An existing Amazon RDS for PostgreSQL production database was created without encryption. A new compliance rule requires encryption at rest with a customer managed key so that key usage can be audited.

The team asks whether they can simply enable encryption on the running instance during the next maintenance window.

What should the solutions architect tell them?

- ☐ A Enable encryption on the existing instance during a maintenance window
- ☐ B Create a snapshot, copy the snapshot with encryption enabled, and restore it as a new instance
- ☐ C Create an encrypted read replica and promote it to be the primary
- ☐ D Enable encryption on the EBS volumes underlying the instance

◆ PAUSE AND DECIDE

What should the solutions architect tell them?

- A** Enable it in a maintenance window

Not possible. Encryption cannot be turned on for an existing unencrypted RDS instance, in a maintenance window or otherwise.
- B** Snapshot, encrypted copy, restore

The documented path. Encryption is applied during the snapshot copy, and the restored instance is encrypted.
- C** Encrypted read replica, then promote

A read replica of an unencrypted instance cannot be encrypted, so the starting point makes this impossible.
- D** Encrypt the underlying EBS volumes

RDS storage is managed. You do not have access to the underlying volumes to modify them.

THE SIGNAL

Encrypting an existing unencrypted RDS database always follows the same three steps. Memorise them.

An application in account A must decrypt objects in an S3 bucket owned by account B. The objects are encrypted with a customer managed KMS key that also lives in account B.

The role in account A has been granted s3:GetObject on the bucket, and the bucket policy permits the role. Downloads still fail with an access denied error.

What is missing?

- ☐ A The KMS key policy in account B must allow the role in account A to use the key
- ☐ B The bucket must be replicated into account A before it can be read
- ☐ C Account A must create an identical KMS key with the same alias
- ☐ D S3 objects encrypted with KMS cannot be read across accounts

◆ PAUSE AND DECIDE

What is missing?

- A

 KMS key policy must allow the role
Reading an encrypted object needs two permissions: read the object, and use the key to decrypt it. Only the first was granted.
- B

 Replicate the bucket
An enormous workaround for a missing permission, and the replica would face the same key access problem.
- C

 Duplicate the KMS key
Keys are not interchangeable. A different key with the same alias cannot decrypt data encrypted by the original.
- D

 Not possible across accounts
An invented restriction. Cross-account access to KMS encrypted objects is a supported and common pattern.

THE SIGNAL

Encrypted object access always needs two grants: one on the object, one on the key. Forgetting the key grant is the classic failure.

A company runs a public website behind CloudFront. Its TLS certificate expired overnight, causing a two-hour outage. Investigation shows the certificate was purchased externally, installed manually, and the renewal reminder went to a member of staff who left.

The company wants this to be impossible in future, at the lowest cost.

What should the solutions architect recommend?

- ☐ A Purchase a three-year certificate and set a calendar reminder shared with the team
- ☐ B Request a public certificate from AWS Certificate Manager and associate it with the distribution
- ☐ C Use AWS Private Certificate Authority to issue the website certificate
- ☐ D Store the certificate in Secrets Manager with rotation enabled

◆ PAUSE AND DECIDE

What should the solutions architect recommend?

- A

 Longer certificate and a reminder
Still depends on a human noticing. It delays the same failure rather than removing it, and costs money.
- B

 ACM public certificate on CloudFront
Free for use with CloudFront, and renewal is managed automatically with no human in the loop.
- C

 Private Certificate Authority
Issues certificates trusted only inside your organisation. Public browsers would reject them, and the service carries a monthly charge.
- D

 Certificate in Secrets Manager
Secure storage does not renew a certificate. The expiry problem is untouched.

THE SIGNAL

Public website plus expiry plus lowest cost equals ACM. Private CA is for internal trust, and is never the cheap option.

Module 3 takeaways

- ◆ **Any key requirement** beyond 'it is encrypted' means a customer managed KMS key.
- ◆ **Encrypted object access needs two grants:** one on the object, one on the key.
- ◆ **Rotation** means Secrets Manager. Cheap config means Parameter Store.
- ◆ **CloudTrail records actions. Config records state.** Macie reads objects, Inspector scans workloads, GuardDuty reads logs.
- ◆ **Encrypting existing RDS or EBS** is always snapshot, encrypted copy, restore.

ON THE EXAM

That completes domain one, thirty percent of the exam. Next we move to resilience.